

Module 5 Report:

Designing a Security Model for a Healthcare Startup

JR Clark (002035589)
NEU DAMG7350 (Spring 2026)

Introduction

Healthcare startups operate under intense pressure: they must innovate quickly while protecting some of the most sensitive data in the world. As emphasized in the Module 5 readings, modern cybersecurity is not a reactive discipline but a secure-by-design practice grounded in principles such as least privilege, segregation of duties, defense in depth, and Zero Trust.

My professional experience reinforces this critical insight: *security failures rarely stem from missing tools*. Instead, they emerge from unclear ownership, inconsistent escalation paths, and teams that have never practiced how to work together when systems degrade. This paper proposes a security architecture for a healthcare startup that integrates technical controls with organizational readiness.

Core System Architecture

Identity and Access Management (IAM): Identity is the new perimeter in cloud-first healthcare environments. The architecture begins with a centralized IAM platform such as Azure AD or Okta. Access follows a deny-by-default model, with JIT and PAM reducing long-lived privileges and ensuring administrative actions remain auditable. Automated provisioning and deprovisioning prevent orphaned accounts and reduce the risk of unauthorized access.

Operationally, IAM requires clear ownership. Security governs policies, IT or DevOps manages provisioning workflows, and Compliance oversees privileged access approvals. Each function has a designated backup SME to ensure continuity during outages or personnel turnover.

Application and Data Layer: The application layer is built on a microservices architecture with an API gateway enforcing authentication, authorization, and rate limiting. All PHI is encrypted in transit using TLS 1.2+ and at rest using AES-256. Sensitive data is further protected through tokenization or format-preserving encryption. Environments are segmented—

production, staging, and development operate in isolated networks to prevent accidental exposure of PHI in non-production systems.

This design reflects the principles of defense in depth and complete mediation.

Engineering teams own service-level access controls, while data governance teams maintain PHI classification rules and tokenization policies.

Infrastructure Layer: The infrastructure layer applies Zero Trust network segmentation, eliminating flat networks and reducing lateral movement. Kubernetes orchestrates containerized workloads, with Open Policy Agent (OPA) and Gatekeeper enforcing security policies at deployment time. Infrastructure-as-Code (IaC) using Terraform ensures reproducibility, reduces configuration drift, and aligns with the principle of economy of mechanism—keeping systems simple, predictable, and secure. DevOps owns IaC pipelines, Security reviews and approves policies.

Monitoring, Logging, Governance, and Organizational Readiness: A secure architecture must be observable. A Security Information and Event Management (SIEM) platform aggregates logs from IAM, applications, infrastructure, and endpoints.

However, monitoring alone is insufficient without governance. Incident response workflows are documented and mapped to a RACI model that clarifies who is responsible, accountable, consulted, and informed during incidents. This eliminates ambiguity and ensures

that every alert has a clear owner and escalation path.

Disaster Recovery, Organizational Behavior, and

Cross-Functional Coordination

Operationalization is a core security requirement. A system cannot be considered secure if the people responsible for maintaining it do not understand how it behaves during failure or how to coordinate across functions when normal workflows break down. To address this, the architecture incorporates a structured disaster recovery (DR) and organizational readiness program built around clear ownership, documented processes, and regular cross-functional drills. Every critical system—including IAM, cloud infrastructure, PHI databases, CI/CD pipelines, SaaS platforms, and monitoring tools—has a primary SME, a trained backup, and a substitute SME for extended outages. Disaster recovery runbooks outline step-by-step actions for cloud region failures, database corruption, credential compromise, ransomware, vendor outages, and SaaS disruptions such as AEM, Salesforce, or Marketo downtime.

Cross-functional DR drills, conducted two to four times per year, simulate realistic failure scenarios and require participation from engineering, security, DevOps, compliance, data governance, and leadership observers. As part of these drills, teams perform a SaaS dependency mapping exercise to identify which internal systems rely on external vendors and how outages propagate across workflows. Drills validate documentation, ensure backup SMEs can execute procedures, and expose gaps in tooling or communication. Post-drill reviews feed directly into

Security Principles Applied

- **Least Privilege:** Users and systems receive only the minimum access required to perform their roles.
- **Segregation of Duties:** No single individual can create users, approve access, and deploy code to production..
- **Defense in Depth:** Multiple layers of protection—IAM, API gateway, microservices, encryption, SIEM, and governance—ensure that no single control failure leads to a breach.
- **Zero Trust Architecture:** Zero Trust eliminates implicit trust and requires continuous verification of identity, device posture, and context.
- **Auditability and Accountability:** Immutable logs, access reviews, and documented workflows ensure that actions are traceable and verifiable.

updated runbooks and improved training. Embedding DR drills into the architecture transforms security from a theoretical design into a practiced organizational capability.

Technical Justification

The proposed architecture is grounded in evidence-based security practices and real-world operational experience. Centralized IAM reduces the risk of over-permissioning, while JIT access minimizes long-lived credentials. Immutable logs support forensic readiness and regulatory audits. Zero Trust reduces reliance on perimeter defenses, and IaC ensures reproducibility and secure defaults.

Most importantly, disaster recovery drills operationalize the architecture. They ensure that every control has an accountable owner, a trained backup, and a documented workflow. This approach addresses a common failure mode observed in enterprise environments: tools existed, but teams lacked clarity on how to act when anomalies occurred.

Regulatory Compliance Analysis

The architecture aligns with HIPAA's Security Rule requirements for access control, audit controls, integrity, authentication, transmission security, and contingency planning, as well as state privacy laws such as CMIA and CPRA. Vendor and third-party risk is addressed through BAAs, SOC 2 alignment, and continuous monitoring of vendor access.

Conclusion

A secure healthcare architecture requires more than technical controls; it requires a cohesive, practiced, and resilient organization. By integrating least privilege, segregation of duties, defense in depth, Zero Trust, and auditability with structured disaster recovery drills and clear ownership, the proposed model ensures both technical and operational readiness. Including SaaS dependency mapping and vendor-specific recovery procedures further strengthens resilience in a cloud-first environment.

REFERENCES:

- Atlassian. (n.d.). Incident management runbooks. Retrieved from <https://www.atlassian.com/incident-management/runbooks>
- California Civil Code §§ 56–56.37 (Confidentiality of Medical Information Act).
- California Privacy Rights Act of 2020, Cal. Civ. Code § 1798.100 et seq.
- Google Cloud. (n.d.). Disaster recovery planning guide. Retrieved from <https://cloud.google.com/architecture/dr-scenarios-planning-guide>
- Health Insurance Portability and Accountability Act of 1996, 45 C.F.R. § 164.308–316.
- Microsoft Azure. (n.d.). Site recovery runbook overview. Retrieved from <https://learn.microsoft.com/en-us/azure/site-recovery/site-recovery-runbook-overview>
- National Institute of Standards and Technology. (2010). Contingency planning guide for federal information systems (NIST SP 800-34 Rev. 1). Retrieved from <https://csrc.nist.gov/publications/detail/sp/800-34/rev-1/final>
- PagerDuty. (n.d.). Incident response documentation. Retrieved from <https://response.pagerduty.com>
- SANS Institute. (n.d.). Tabletop exercise resources. Retrieved from <https://www.sans.org/blog/tabletop-exercise-resources/>
- U.S. Department of Health & Human Services. (n.d.). HIPAA Security Rule. Retrieved from <https://www.hhs.gov/hipaa/for-professionals/security/index.html>

AI Use & Methodology Statement

This paper was developed using a combination of my own analysis, professional experience, and assistance from Microsoft Copilot. Copilot was used to help structure the outline, draft sections of the paper, and generate examples for the appendix, including runbook templates and disaster recovery drill schedules. All AI-generated content was reviewed, edited, and validated by me to ensure accuracy, alignment with course materials, and compliance with Northeastern University’s Academic Integrity and Use of AI policy. I take full responsibility for the final content.

Appendix A: Runbook Template

System Name & Purpose Brief description of the system and its role in PHI/PII workflows.

Primary Owner & Backup SME

- Primary SME: Name, role, contact
- Backup SME: Name, role, contact
- Substitute SME (optional)
- After-hours escalation path including names of business stakeholders or sponsors.

Third-Party Contacts & Dependencies

- Vendor name Service provided
- Data involved (PHI, PII, metadata)
- Vendor status page
- Vendor support portal
- Primary vendor contact
- After-hours/emergency contact
- SLA / RTO / RPO
- Integration points (API, webhooks, SFTP, OAuth tokens)
- Internal systems impacted by vendor outage
- Known failure modes

Internal Dependencies: IAM, network, databases, certificates, internal APIs, etc.

Normal Operating State Key dashboards, expected performance metrics, monitoring views.

Failure Scenarios Covered

- Outage Degraded performance
- Credential compromise
- Data corruption
- SaaS outage
- Vendor outage
- Region failure

Recovery Procedure Numbered steps with links or screenshots.

Verification Steps

- Smoke tests
- Log checks
- Data validation

Communication Requirements

- Stakeholder notifications
- Escalation triggers
- Update cadence

Post-Incident Actions

- Log collection
- Root cause analysis
- Documentation updates
- Compliance notes

Last Updated & Next Scheduled Drill

- Dates and responsible owner.

Appendix B: Sample Disaster Recovery Drill Schedule

Quarter	Drill Type	Systems Involved	Participants	Objectives
Q1	IAM Outage Simulation	IAM, SSO, PAM	Security, DevOps, IT	Validate emergency access procedures
Q2	SaaS Outage Simulation and Dependency Mapping	AEM, Salesforce, Marketo	Engineering, Marketing, Compliance	Validate vendor escalation and map SaaS dependencies
Q3	Database Corruption Drill	PHI DB, backups, API layer	Data Engineering, Security	Validate RPO/RTO and data integrity
Q4	Ransomware Tabletop Exercise	Endpoints, EDR, SIEM	Security, IT, Leadership	Validate communication and containment

Appendix C: Public Resources for Runbooks, RACI, and DR Drills

- Atlassian Runbook Templates: <https://www.atlassian.com/incident-management/runbooks>
- Atlassian RACI Guide: <https://www.atlassian.com/team-playbook/plays/roles-and-responsibilities>
- AWS Disaster Recovery Playbook: <https://docs.aws.amazon.com/prescriptive-guidance/latest/disaster-recovery-playbook/welcome.html>
- Azure Runbook Overview: <https://learn.microsoft.com/en-us/azure/site-recovery/site-recovery-runbook-overview>
- Google Cloud DR Planning Guide: <https://cloud.google.com/architecture/dr-scenarios-planning-guide>
- NIST SP 800-34 Rev.1: <https://csrc.nist.gov/publications/detail/sp/800-34/rev-1/final>
- PagerDuty Incident Response Guide: <https://response.pagerduty.com>
- SANS Tabletop Exercise Resources: <https://www.sans.org/blog/tabletop-exercise-resources/>